POLICE LINES SCHOOL AND COLLEGE, FARIDPUR

GRAND REUNION 2026 / 2027 MANAGEMENT PLATFORM

COMPLETE TECHNICAL ARCHITECTURE, ACCESS & SECURITY AUDIT REPORT

End-to-End Source Code Verification & Vulnerability Audit | Classification: STRICT CONFIDENTIAL | Generated: November 12, 2026

1. Executive Summary

A comprehensive, source-code-based technical audit was conducted on the web platform for Police Lines School & College, Faridpur (Grand Reunion 2026 / 2027). The website manages attendee registrations, payment processing via PayStation, turnstile gate control, multi-session meal distribution, commemorative merchandise delivery, an executive Reunion Management System (RMS), and physical Student ID card production (54 × 86 mm CR80 standard).

The audit examined 32,644 lines of frontend React/TypeScript components, 9,085 lines of store and integration services, 2,488 lines of PostgreSQL migrations across 37 tables, and 815 lines of Supabase Deno Edge Functions. All 81 automated security and regression test suites pass with zero errors.

CRITICAL SECURITY HEADLINE

While the database exhibits advanced security controls (Row Level Security on all 37 tables, HMAC-SHA256 signatures, atomic stored procedures, and anti-replay guards), a client-side development test bypass (isDevTestBypassAllowed) and hardcoded development passwords (admin@123) are bundled into the client distribution. In production, VITE_ENABLE_TEST_BYPASS="false" must be explicitly enforced to eliminate mock administrative session access.

2. System & Infrastructure Architecture

The platform adopts a modern Serverless Single Page Application (SPA) architecture combined with a resilient local cache layer:

System Tier	Technology Stack	Operational Purpose
Frontend Application	React 19, TypeScript 5+, Tailwind CSS v4, Vite 8	Single-page app with route-level code splitting & Lucide icons
Hosting & CDN Delivery	Vercel Edge Network / Netlify Edge	Global HTTPS distribution, Brotli/Gzip compression, asset caching
Database Infrastructure	Supabase Cloud (PostgreSQL 15+ Engine)	37 relational tables, pgcrypto extension, RLS, PostgREST API
Serverless Microservices	Supabase Edge Functions (Deno Runtime)	verify-payment, secure-ticket-lookup, verify-student-id, admin-audit
Payment Gateway	PayStation Payment Gateway (BD Bank	Hosted checkout, bKash, Nagad, Rocket, Upay, Visa, Mastercard
Client Storage Cache	LocalStorage API (AppStore, EventStore)	Instant offline resilience during event day network congestion
Document Generation	jsPDF & HTML5 Canvas 2D Engine	Print-ready 54×86mm CR80 ID cards, A4 gang-run sheets, PNG

3. User Roles and Operational Responsibilities

The codebase implements four distinct, role-based subsystem hierarchies. Permissions are enforced both in the user interface and at the database level via PostgreSQL Row Level Security.

Operational Role	Internal Key	Primary Responsibilities & Scope
Super Administrator	super_admin	Full control across all 37 tables, staff provisioning, fees, and cryptographic
Convener / Secretary	CONVENER	Executive oversight, formal budget approvals, sponsorship agreements, and official
Finance Manager	finance_mgr	Double-entry financial ledger, gateway reconciliations, staff expense allocations, and
Registration Manager	registration_mgr	Student verification, category updates, contact corrections, and attendee support.
ID Card Supervisor	ID_CARD_SUPERVISOR	ID card production queue, 9-cards-per-A4 batch generation, and ZIP packaging.
Turnstile Staff	GATE_STAFF	Campus entry scanning. Views name/photo/badge; sensitive financial/phone PII is
Meal Staff (B/L/D)	BREAKFAST_STAFF	Meal coupon redemption. Strictly isolated to assigned meal; duplicate scans are
Kit / Dress Staff	DRESS_STAFF	T-shirt handout verification. Checks registered size (XS to 50); single redemption rule.

Committee Director	COMMITTEE_DIRECTOR	Directs 1 of 12 sub-committees (Media, Food, Venue, etc.), manages tasks,
Student / Attendee	public / student	Self-service registration, online payment, ticket download, and public badge lookup.

4. User Stories by Persona

AS A STUDENT / ALUMNI MEMBER:

“I can register on the website, upload my photo, pay my registration fee via PayStation, and download my verified digital ticket and ID card. I cannot view another attendee's private contact or financial details.”

AS A SUPER ADMINISTRATOR:

“I have authoritative control over all user accounts, financial ledgers, system settings, and database tables. All my sensitive actions generate permanent, tamper-evident audit logs that cannot be altered or erased.”

AS A FINANCE MANAGER:

“I can inspect all verified payment transactions, balance merchant collections, disburse operational budgets to staff, and record verified expense receipts. I cannot alter student personal identity details or bypass the audit log.”

AS A GATE ENTRY OFFICER:

“I can scan attendee QR codes and tokens at campus turnstiles to authorize entry. I see the attendee's verified photo, name, and batch, but their personal phone numbers, addresses, and payment details remain hidden.”

AS A FOOD SERVICE OFFICER:

“I can redeem meal coupons for my specific assigned session (Breakfast, Lunch, or Dinner). The system automatically prevents double collections and rejects me if I attempt to approve services outside my department.”

AS AN ID CARD SUPERVISOR:

“I can review student badge readiness, generate official 54×86mm CR80 cards, and download organized 9-cards-per-sheet A4 PDFs and hierarchical ZIP archives for physical badge printing.”

5. Complete Database Overview (37 Tables)

The PostgreSQL database is organized into four interconnected domains with strict referential integrity, indexes, and Row Level Security policies:

Database Domain	Key Tables Included	Functional Scope & Data Held
Core Registrations	registrations_2027, registrations_2026	Attendee profiles, 6-char QR tokens, gateway invoices, payment
Donations & Patrons	donations_2027, donations_2026	Philanthropic donations, payment methods, transaction references,
Staff & Authentication	admin_accounts, staff_accounts,	Accounts linked to Supabase Auth UID, department isolation, and
Event Operations	food_distributions, dress_distributions, gate_events	Atomic distribution logs, turnstile scans, meal redemptions, duplicate
Financial Ledger	financial_ledger, central_budget, staff_allocations	Immutable double-entry ledger tracking all inflows, staff allocations,
Reunion ERP (RMS)	rms_committees, rms_tasks,	14 tables managing committees, tasks, budgets, sponsors,
ID Card Production	student_id_cards, batch_id_card_collections, jobs	Badge generation statuses, file sizes, 9-cards-per-A4 sheets, and
Security & Rate Limits	private.ticket_lookup_rate_limits, admin_audit_logs	HMAC-hashed IP rate limiting table and SHA-256 tamper-evident

6. Security Audit Findings & Vulnerabilities

The security audit evaluated the platform against the OWASP Top 10 web application vulnerabilities, access control enforcement, cryptographic integrity, and data leakage:

ID	Vulnerability Finding Title	File & Line Evidence	Risk	Required Mitigation
SEC-01	Universal Test Bypass & Hardcoded	src/services/supabase.ts:51	CRITICAL	Disable VITE_ENABLE_TEST_BYPASS in
SEC-02	Client-Side LocalStorage Fallback Mutations	src/services/store.ts:1451	HIGH	Enforce server verification for all offline

SEC-03	ID Card Staff Unlinked from Supabase Auth	src/services/idCardStore.ts:46	HIGH	Migrate ID card staff accounts to
SEC-04	Default HMAC Signing Secret in Payment	verify-payment/index.ts:15	MEDIUM	Require PAYMENT_SIGNING_SECRET
SEC-05	PayStation Sandbox Token Fallback in Edge	verify-payment/index.ts:58	MEDIUM	Remove sandbox simulation tokens from
SEC-06	Client-Side In-Memory Rate Limiter Map	src/utils/security.ts:285	LOW	Mitigated by server-side DB rate limit in
SEC-07	Pre-seeded Demo Attendee PII in Bundle	src/services/store.ts:131	LOW	Clear INITIAL_REGISTRATIONS array
SEC-08	Client-Side Button Hiding as Secondary	AdminDashboard.tsx:280	LOW	Mitigated by PostgreSQL RLS on all

7. Data Lifecycle & Searching Performance

Attendee data flows through a verified lifecycle: Public registration (Form submission -> Image compression -> Pending DB insertion -> PayStation checkout -> Callback -> Server-side HMAC-SHA256 signature -> Paid update -> Ledger credit -> ID card generation).

Query optimization highlights: Searches utilize specialized PostgreSQL indexes including idx_reg_2027_mobile, idx_reg_2027_qr, idx_reg_2027_gateway_inv, and uq_registrations_2027_mobile_normalized. Full-table scans are prevented during ticket verification and gate scanning. Server-side paginated queries (fetchRegistrationsPaginated) ensure fluid 60 FPS performance even with 10,000+ registrations.

8. Technical Glossary

Term	Architectural Definition & Context
CR80 Standard	Standard credit-card physical dimensions (54 × 86 mm / 3.370 × 2.125 inches) with 3.18mm corner radius.
Row Level Security (RLS)	PostgreSQL security mechanism enforcing access policies on individual rows based on user role and identity.
HMAC-SHA256	Hash-based Message Authentication Code combining a secret cryptographic key with data to guarantee authenticity.
Anti-Replay Protection	Database constraint preventing an already-used payment transaction ID from being claimed by another attendee.
Department Isolation	Role-Based Access Control rule preventing staff assigned to one area (e.g. Breakfast) from acting in another.
Maker-Checker Rule	Two-person authorization control requiring one administrator to initiate an action and another to approve it.